

Phase 7 組織・権限管理 完了報告書

現場 OS Lite / サインアップ・招待コード・ロール・メンバー管理・現場の担当割当

作成日：2026 年 6 月 25 日 / 目的：会社（テナント）単位で安全に複数人運用できる

結論：Phase 7 完了 ☒（実装・テスト・CI・dev 実機 すべてクリア）

「単一ユーザー前提」から「チームで使えるアプリ」へ移行。アプリ内サインアップ、招待コードでの会社参加、ロール(owner/admin/member)と権限ゲート、メンバー管理、現場の担当割当を追加。flutter analyze=**No issues** / flutter test=**73 件 全合格** / iOS ビルド成功 / **CI 緑 (7a/7b/7c)**。dev 実機で一連の流れ（サインアップ→会社作成→招待→ロール変更→担当割当）を確認。セキュリティ上の既存の穴（自己昇格）も本フェーズで封鎖。

1. 実装した機能

機能	内容
サインアップ (7a)	アプリ内でメール+パスワード新規登録。登録後はホームで会社参加/作成へ誘導。
会社に参加 / 作成 (7a)	①招待コード入力で参加 ②会社を新規作成して自分が owner。会社未所属はホーム内で分岐表示。
ロール+権限ゲート (7a)	owner / admin / member。管理操作は UI で出し分け+ DB (RLS/RPC) でも強制。
メンバー管理 (7b)	自社メンバー一覧。owner/admin が member⇔admin を変更（自分・owner は対象外）。
招待コード (7b)	owner/admin が発行（付与ロール選択）・コピー・失効。8 桁・期限 7 日。
現場の担当割当 (7c)	現場詳細の「担当メンバー」。owner/admin が自社メンバーを割当/解除。閲覧は会社単位のまま。

2. スcope (実装した / しない)

実装した (MVP)	非対象 (後続・対象外)
サインアップ/会社参加（招待コード）/会社作成	メンバーの除名（会社からの削除）
ロール owner/admin/member + 権限ゲート	owner の付替え（最後の owner 事故を防止）
メンバー一覧・ロール変更（member⇔admin）	確認メールの高度化（dev は確認 OFF 前提）
招待コードの発行・失効	「担当現場のみ閲覧」への RLS 厳格化（会社単位の閲覧は維持）
現場の担当メンバー割当（site_members）	ロールによる 現場/日報/写真 の編集制限（全員可を維持）

3. DB 変更（マイグレーション 0005_org_roles.sql・dev 適用済み）

対象	内容
関数	current_role() (RLS 再帰回避・definer)
ポリシー修正	profiles 自己更新で company_id / role を変更不可 （旧値一致を要求）= 自己昇格の穴を封鎖
テーブル	company_invites（招待コード）/site_members（現場の担当割当）+ 各 RLS
RPC (definer)	redeem_invite（参加）/create_company（作成→owner）/set_member_role（ロール変更）

※ 会社割当・ロール変更は security definer RPC からのみ実行可能。クライアントから直接 company_id/role は書けない。※ prod は本番化時に 0001~0005 を順に適用 (dev は適用済み)。

4. セキュリティ設計 (要点)

- ・ **自己昇格の封鎖**：従来 profiles の自己更新で role/company を自由に変えられたが、with check で旧値一致を要求し封鎖。会社割当・ロール変更は definer RPC 経由のみ。
- ・ **二重の権限制御**：UI でボタンを出し分け (owner/admin のみ) + RLS/RPC で DB 強制。member が API を直接叩いても変更不可。
- ・ **最後の owner 保護**：owner は変更対象外・自分のロールは変更不可 → owner が消える事故を構造的に回避。
- ・ **マルチテナント維持**：すべて会社単位 (current_company_id())。招待コードは自社のみ発行・参加は会社未所属者のみ。

5. 追加・変更ファイル (主なもの)

区分	ファイル
追加 (org)	org/data/ : org_repository・invite(.dart+モデル)・invite_repository・member_repository / org/application/ : join_controller・members_providers・member_controller・invite_controller / org/presentation/ : join_company_view・members_screen
追加 (auth/sites)	auth/application/current_profile_provider.dart・auth/presentation/signup_screen.dart / sites/data/site_member_repository.dart・sites/application/site_member_controller.dart
追加 (DB)	supabase/migrations/0005_org_roles.sql
変更	auth_repository(signUp)・auth_controller(signUp)・auth_providers / login_screen(登録導線) / home_screen(会社分岐+メンバー管理導線) / site_detail_screen(担当メンバー) / app_routes・app_router(/signup・/members・authRedirect)
テスト	追加 : join/member/invite/site_member の各 Controller+モデル / 変更 : auth_redirect(signup)・auth_controller(signUp)・auth fakes

6. 品質チェック結果

項目	結果	内容
flutter analyze	No issues	警告・エラー 0
flutter test	73 / 73 緑	Phase 7 で新規 21 件 (7a 10+7b 7+7c 4)。既存 52 件も緑
iOS ビルド	成功	flutter build ios --simulator --flavor dev (新規ネイティブ依存なし)
CI (GitHub Actions)	緑	7a 727bec4 / 7b a56197b / 7c 44001ed (build_runner→analyze→test)
dev 実機	確認済み	サインアップ→会社作成／招待発行→別アカ参加／ロール変更／担当割当 (ユーザー確認 2026-06-25)

新規テストの内訳 (21 件)

- 7a : authRedirect(signup 2)・AuthController.signUp(2)・JoinController(4)・orgErrorMessage(2)
- 7b : MemberController(2)・InviteController(3)・Invite.isActive(2)
- 7c : SiteMemberController(3)・AssignedMember.fromJson(1)

7. 完了条件チェック

#	条件	判定
1	サインアップできる	✓
2	招待コードで会社に参加できる	✓
3	会社を新規作成して owner になれる	✓
4	owner/admin がロールを member⇔admin に変更できる	✓
5	owner/admin が現場に担当メンバーを割当/解除できる	✓
6	自己昇格不可 (直接 API で role/company を書き換え不可)	✓
7	会社単位の RLS 維持 (自社データのみ)	✓
8	analyze / test / CI / dev 実機	✓

8. 完了判定

Phase 7 は完了。実装・自動テスト (73 件)・CI・iOS ビルド・dev 実機確認 すべてクリア。migration 0005 を dev に適用済み。複数人運用の土台 (参加・ロール・担当割当) が整い、顧客に「チームで使える」状態を提示できる。prod 化時に 0005 を適用すれば本番でも利用可能。

9. ROADMAP 更新内容

- Phase 7 (組織・権限管理) を  → 完了 (2026-06-25)。
- ★現在地を「**Phase 1~4 + 6 + 7 完了**」に更新。残るは Phase 5 (通知・連携) と 8~10。
- Phase 5 は **飛ばし中** と明記 (APNs/FCM の証明書設定が必要なため後着手)。
- 本番化前の残 : prod へ 0001~0004 + **0005** を順に適用。

10. 次フェーズの提案

候補	内容・狙い	推奨度
Phase 8 品質強化	テスト網羅・クラッシュ監視・パフォーマンス・アクセシビリティ。リリース品質づくり。外部設定が軽い	◎ 推奨
Phase 5 通知・連携	飛ばし中。プッシュ通知は APNs/FCM の証明書設定が重い。まず「現場内お知らせ/コメント」等の軽い範囲から始めると着手しやすい	○
ベータ準備 (Phase 9 寄り)	TestFlight 配信で実機ベータ。実利用フィードバックを得る	○

推奨：Phase 8（品質強化）または Phase 5 の軽量スコープ。 主要機能（現場/日報/写真/帳票/組織）が揃ったため、次は「品質を固めて配信へ」か「飛ばした通知を軽い範囲で回収」のどちらか。Phase 5 を選ぶ場合は、証明書設定の要否で重さが変わるため **要件定義の前にスコープ相談** を推奨。いずれも着手時は **要件定義書 → 承認 → 実装仕様書 → 実装 → analyze/test/CI/実機 → 完了報告** の順に進めます。